

MAIE6000B Generative AI in Finance

Homework #2

REN KAIYAN

21270191

May 9, 2026

Contents

1	Question 1: Hong Kong Regulatory Evolution	3
2	Question 2: OECD AI Principles	4
2.1	Selected Principles and Their Conflict	4
2.2	Nature of the Conflict	4
2.3	Recommended Balancing Approach	5
3	Question 3: BIS on Customer-Facing Use Cases	6
3.1	Reason 1: Direct Consumer Harm Through Misleading or Inaccurate Outputs	6
3.2	Reason 2: Regulatory, Suitability, and Conduct Obligations	7
3.3	Reason 3: Reputational and Legal Liability Exposure	7
3.4	Summary Distinction	8
4	Question 4: IOSCO Risk Categories	8
4.1	Herding Behaviour as a Systemic Risk	8
4.2	Mechanisms of AI-Amplified Herding	8
4.3	Consequences for Market Stability	9
5	Question 5: FSB Financial Stability Implications	10
5.1	Mechanism of Correlation Vulnerability	10
5.2	Consequences During Periods of Stress	11
6	Question 6: Fairness and Bias Mitigation	11
6.1	Pre-processing: Reweighting Training Samples	12
6.2	In-processing: Adversarial Debiasing	12
6.3	Post-processing: Group-Specific Threshold Calibration	13
6.4	Integration Across Stages	13
7	Question 7: Transparency and Explainability Layers	14
7.1	Why Different Stakeholders Require Different Explanations	14
7.2	End User Level: Loan Decision Scenario	14
7.3	Technical Auditor Level: Loan Decision Scenario	15
7.4	Justification for Differentiation	15
8	Question 8: Accountability in the AI Value Chain	15
8.1	The Air Canada Chatbot Case	15
8.2	Where the Accountability Gap Occurred	16
8.3	Governance Mechanisms That Could Have Prevented Harm	16

9	Question 9: Hong Kong Privacy Framework	17
9.1	Human Oversight and Privacy Protection in GenAI	17
9.2	Practice 1: Privacy Impact Assessment with Human Review at Each Life-cycle Stage	18
9.3	Practice 2: Human-Gated Escalation for Outputs Involving Personal Data	18
10	Question 10: Hallucinations and Model Risk	19
10.1	Three Safeguards for High-Risk Use Cases	19
10.1.1	Safeguard 1: Mandatory Grounding with Source Attribution . . .	19
10.1.2	Safeguard 2: Multi-Layer Output Validation	20
10.1.3	Safeguard 3: Human Review with Defined Escalation Criteria . .	20
10.2	Why Traditional Model Validation is Insufficient for GenAI	20

1 Question 1: Hong Kong Regulatory Evolution

The HKMA’s decision to issue additional guidance specifically for generative AI in August 2024, five years after its original High-level Principles on AI in November 2019, reflects the fact that the original framework was not designed for the kinds of AI risk that have since emerged. The 2019 principles were crafted for an era of traditional AI applications in banking, which were predominantly predictive and classificatory in nature. These included credit scoring models, fraud detection systems, and customer segmentation tools. Such systems operate within well-defined input-output mappings: they receive structured data and produce discrete predictions or classifications. Their failure modes are relatively bounded and can be assessed using conventional model validation techniques such as backtesting, sensitivity analysis, and statistical performance metrics.

Generative AI creates risks that were not clearly visible when the 2019 principles were issued. The most significant departure is that generative models produce open-ended, natural-language outputs rather than constrained predictions. This means that the space of possible outputs is effectively unbounded, making exhaustive testing impossible. A traditional credit scoring model either approves or denies a loan within a known decision boundary. A generative AI system advising a customer on investment suitability could produce an infinite variety of responses, some of which may be factually incorrect, misleading, or non-compliant with regulatory requirements, while appearing entirely fluent and authoritative.

Several unique risks necessitated the updated guidance. First, hallucination risk is intrinsic to generative models. These systems can produce outputs that are linguistically coherent but factually baseless. In a financial context, this could mean fabricating regulatory requirements, inventing product features, or misrepresenting terms and conditions. Unlike traditional AI, where errors manifest as measurable deviations from ground truth, generative hallucinations can be difficult to detect precisely because they are expressed with surface-level confidence.

Second, generative AI introduces a new category of consumer interaction risk. When a bank deploys a generative chatbot for customer service, the system is not merely retrieving pre-approved responses from a knowledge base. It is constructing novel responses in real time, creating the possibility that it will make representations or commitments that the institution has not authorised. The Air Canada chatbot case, in which a generative system promised a bereavement fare that did not exist, illustrates this risk directly.

Third, generative AI creates unprecedented third-party dependency and concentration risk. Unlike traditional AI models that banks typically develop or customise internally, generative AI relies heavily on foundation models provided by a small number of external

vendors. This introduces opacity regarding training data provenance, model behaviour under edge cases, and the institution’s ability to explain or control outputs. The HKMA’s 2019 principles assumed that institutions would have substantial control over their AI systems’ development and behaviour, an assumption that foundation-model dependency fundamentally undermines.

Fourth, data privacy risks are amplified in generative AI. Foundation models may have been trained on data of uncertain provenance, potentially including personal information processed without consent. When these models are deployed in customer-facing applications, there is a risk that they may inadvertently reproduce or reveal sensitive information from their training data. This represents a privacy concern with no clear analogue in traditional AI applications that process only structured institutional data.

Finally, the speed and scale at which generative AI can be deployed across an institution creates operational risk amplification. A flawed traditional AI model might affect one decision process. A flawed generative AI system deployed as a general-purpose assistant could simultaneously affect customer communications, compliance interpretations, risk assessments, and internal reporting, creating correlated failures across multiple business functions.

The HKMA’s updated guidance therefore represents a recognition that generative AI is not simply an incremental improvement over traditional AI but a categorically different technology requiring purpose-built safeguards for consumer protection, output governance, and institutional accountability.

2 Question 2: OECD AI Principles

2.1 Selected Principles and Their Conflict

The two OECD principles selected for analysis are **transparency and explainability** and **robustness, security, and safety**. In a practical financial services application, these principles can come into direct tension with one another, creating genuine design dilemmas that institutions must navigate.

2.2 Nature of the Conflict

Transparency and explainability require that AI systems provide meaningful information about how they arrive at decisions. In financial services, this translates into obligations such as explaining why a credit application was denied, disclosing the factors that influenced an investment recommendation, or making the logic of a fraud detection system

understandable to auditors. Achieving these goals typically requires either using inherently interpretable models or providing post-hoc explanations of complex models.

Robustness, security, and safety require that AI systems function reliably under adversarial conditions and resist manipulation. In financial services, this means that models should be resistant to gaming by fraudsters, resilient to adversarial inputs designed to exploit weaknesses, and secure against attempts to reverse-engineer their decision logic.

The conflict arises because transparency can directly undermine security. Consider a fraud detection system deployed by a bank. Full transparency about the model’s decision logic, including which features it weighs most heavily and where its decision boundaries lie, would enable fraudsters to engineer transactions that fall just below detection thresholds. The more explainable the system is, the more vulnerable it becomes to adversarial manipulation. Conversely, the more robust and secure the system is against gaming, the more opaque its decision logic must remain to external parties, potentially including the customers affected by its decisions.

A second dimension of conflict exists at the architectural level. The most robust and accurate models in financial applications are often deep neural networks or ensemble methods that are inherently difficult to explain. Constraining institutions to use only transparently interpretable models such as logistic regression or shallow decision trees may improve explainability but reduce the system’s robustness against complex attack patterns and its accuracy in detecting sophisticated fraud typologies. The institution is forced to choose between a system that is explainable but potentially less safe, and one that is safe but less explainable.

A third tension manifests in the context of model updates and security patches. Transparency principles may require institutions to disclose when models are updated and how their behaviour has changed. However, disclosing the timing and nature of security-related model updates could signal to adversaries precisely when vulnerabilities have been addressed, enabling them to exploit the window before updates are deployed.

2.3 Recommended Balancing Approach

Balancing these competing principles requires a differentiated approach rather than treating them as absolute requirements of equal weight in all contexts. The resolution should be guided by three design principles.

First, institutions should adopt layered transparency that calibrates disclosure to the stakeholder’s role and the security implications. Regulators and technical auditors should receive full model documentation including architecture, training data composition, and performance metrics, subject to confidentiality agreements. End users affected by deci-

sions should receive meaningful explanations of the key factors influencing their outcome, without exposing specific thresholds or decision boundaries that could enable gaming. The general public should receive high-level information about the types of AI used and the governance framework in place.

Second, institutions should implement temporal separation between transparency and security measures. Rather than disclosing model logic in real time, institutions can provide retrospective explanations after a reasonable delay, reducing the window for adversarial exploitation while still meeting accountability requirements.

Third, regulators should accept risk-proportionate trade-offs. For high-security applications such as fraud detection and anti-money laundering, reduced explainability to external parties may be justified if compensated by enhanced internal governance, independent auditing, and robust appeal mechanisms for affected individuals. For lower-security applications such as investment suitability assessments, greater transparency can be provided without materially compromising system integrity.

This approach acknowledges that neither principle should be treated as lexicographically superior to the other. Instead, the appropriate balance is determined by context, stakeholder needs, and the specific harm profile of the application.

3 Question 3: BIS on Customer-Facing Use Cases

The Bank for International Settlements identifies customer-facing generative AI applications as particularly high-risk for financial institutions. This elevated risk classification reflects three distinct but reinforcing concerns that differentiate external deployment from internal operational use.

3.1 Reason 1: Direct Consumer Harm Through Misleading or Inaccurate Outputs

The most immediate risk is that generative AI may provide customers with information that is factually incorrect, incomplete, or misleading, and that customers may reasonably rely upon this information for financial decisions. Unlike internal use cases where expert staff can recognise and correct errors before they cause harm, customer-facing systems deliver outputs directly to individuals who may lack the expertise to evaluate their accuracy.

In financial services specifically, this risk is amplified by the advisory relationship. When a bank deploys a generative AI system that interacts with customers about products, terms, or investment options, the customer reasonably interprets the system's outputs

as representing the institution’s position. A hallucinated product feature, an incorrect interest rate calculation, or a misleading risk disclosure could directly cause financial loss to the customer. The BIS recognises that the fluency of generative AI outputs makes this risk particularly insidious, because customers are less likely to question information that is articulated confidently and coherently.

Internal operational use cases carry substantially lower risk in this dimension because outputs are consumed by trained professionals operating within institutional review processes. An internal analyst receiving a generative AI summary of a regulatory document has the expertise and contextual knowledge to identify inconsistencies, and institutional workflows typically require verification before action is taken.

3.2 Reason 2: Regulatory, Suitability, and Conduct Obligations

Customer-facing applications trigger a dense web of regulatory obligations that internal tools do not. Financial institutions are subject to suitability requirements, fair dealing obligations, disclosure standards, and consumer protection regulations that apply specifically to customer interactions. When a generative AI system communicates with customers about financial products, it effectively assumes the institution’s regulatory obligations regarding accuracy, completeness, and appropriateness of information.

The BIS notes that generative AI systems cannot currently be relied upon to consistently satisfy these obligations because they lack genuine understanding of individual customer circumstances, regulatory boundaries, and the legal implications of their statements. A system might recommend a complex derivative product to a retail customer without assessing suitability, or fail to provide mandatory risk disclosures, or make forward-looking statements that constitute unauthorised financial advice.

Internal use cases are subject to different and generally less onerous regulatory requirements. An AI system that assists with internal risk reporting or operational planning does not trigger consumer protection regulations, suitability obligations, or fair dealing requirements. The regulatory exposure is fundamentally different.

3.3 Reason 3: Reputational and Legal Liability Exposure

Customer-facing generative AI creates direct legal liability exposure because outputs constitute representations made by the institution to its clients. If a generative system makes a commitment, provides incorrect information that a customer relies upon, or discriminates in its treatment of different customer groups, the institution faces potential litigation, regulatory enforcement, and reputational damage.

The BIS emphasises that institutions cannot disclaim responsibility for outputs generated

by their AI systems simply because those outputs were not pre-approved by a human. The deploying institution bears accountability for all customer communications regardless of the technology used to generate them. This creates a liability surface that scales with the volume and variety of customer interactions handled by the system.

Internal use cases do not create this external liability exposure. Errors in internal AI outputs may lead to suboptimal decisions, but they do not directly create legal claims from third parties or trigger consumer protection enforcement actions. The harm pathway is indirect and typically mediated by human decision-makers who bear professional responsibility for their actions.

3.4 Summary Distinction

The key difference between customer-facing and internal use cases is that internal applications still involve trained staff checking and mediating the output before it has real-world consequences, while customer-facing applications deliver AI outputs directly to end users who may not be in a position to evaluate their accuracy, compliance, or appropriateness.

4 Question 4: IOSCO Risk Categories

4.1 Herding Behaviour as a Systemic Risk

Herding behaviour in financial markets refers to the phenomenon whereby a large number of market participants make similar investment decisions at approximately the same time, moving in the same direction regardless of their individual information or risk assessments. In traditional finance, herding arises from behavioural factors such as information cascades, reputational incentives, and the rational imitation of perceived leaders. The consequence is artificially correlated positions that amplify price movements beyond what fundamentals would justify, increasing the probability and severity of market dislocations.

IOSCO has identified AI systems as a potential amplifier of herding behaviour through mechanisms that are qualitatively different from, and potentially more dangerous than, traditional behavioural herding.

4.2 Mechanisms of AI-Amplified Herding

The first mechanism operates through training data homogeneity. When multiple institutions train their trading or risk management AI systems on overlapping datasets, particularly common market data feeds, similar historical price series, and shared alternative data sources, the resulting models tend to learn similar patterns and generate

correlated signals. Unlike human traders who may interpret the same information differently based on experience, institutional culture, or contrarian instincts, AI systems trained on similar data with similar architectures and objectives will tend to converge on similar outputs. This creates a structural correlation in decision-making that is invisible to any individual institution but systemically significant in aggregate.

The second mechanism operates through model architecture convergence. The AI ecosystem in finance is increasingly dominated by a small number of foundational approaches, including transformer architectures, reinforcement learning frameworks, and specific feature engineering methodologies. When many institutions adopt similar model architectures, even if trained on somewhat different data, the inductive biases of these architectures can produce correlated behaviour. The models may respond similarly to novel market conditions because they share structural assumptions about how to process and weight information.

The third mechanism is speed and synchronisation. AI systems operate at speeds far exceeding human decision-making. When multiple AI systems detect the same signal and initiate the same response, their actions are nearly simultaneous rather than staggered over hours or days as would be the case with human traders. This temporal compression means that the market impact of correlated decisions is concentrated into a narrow window, potentially overwhelming market liquidity and amplifying price dislocations.

The fourth mechanism involves feedback loops and reflexivity. AI systems that are trained on market data and whose outputs influence market prices create a recursive dynamic. If multiple systems learn from the same market movements that their own collective actions have caused, they may reinforce each other's behaviour in a self-amplifying cycle. A sell signal generated by multiple systems simultaneously causes a price decline, which generates further sell signals from the same or similar systems, creating cascading effects that bear no relationship to fundamental value changes.

4.3 Consequences for Market Stability

The systemic implications are substantial. AI-driven herding could produce flash crashes of unprecedented speed and magnitude, as correlated unwinding of positions overwhelms market-making capacity. It could also create false signals of fundamental deterioration, triggering risk management responses from institutions not directly using AI trading systems but responding to the price movements that AI herding has generated. In extreme cases, coordinated AI selling could create liquidity spirals in which falling prices trigger margin calls, forced liquidations, and further price declines in a self-reinforcing mechanism that human circuit-breakers may be too slow to arrest.

IOSCO's concern is therefore not merely that AI systems might make similar errors, but

that the structural characteristics of AI adoption in capital markets—data homogeneity, architectural convergence, speed of execution, and feedback sensitivity—create conditions for correlated behaviour at a scale and speed that could threaten market functioning.

5 Question 5: FSB Financial Stability Implications

5.1 Mechanism of Correlation Vulnerability

The Financial Stability Board’s analysis identifies a specific causal chain through which widespread AI adoption could increase systemic correlation in financial markets. This operates through multiple reinforcing channels that collectively transform what appears to be independent decision-making into structurally correlated behaviour.

The starting point is the concentration of foundational AI capabilities. A small number of foundation model providers supply the underlying technology used across many financial institutions. Even when institutions fine-tune or customise these models for their specific purposes, the base representations, learned patterns, and implicit assumptions of the foundation model persist. Two banks using the same foundation model for credit risk assessment may arrive at different specific outputs, but their assessments will share systematic biases and sensitivities inherited from the common base model. This creates a hidden correlation in risk perception across institutions that is not captured by traditional measures of interconnectedness.

The second channel operates through training data overlap. Financial institutions necessarily draw on many of the same data sources: market data feeds, credit bureau information, macroeconomic indicators, and industry databases. When AI models are trained on substantially overlapping data, they learn similar representations of risk and opportunity. This means that their outputs will be correlated not merely because they are responding to the same external signals, but because they have learned to process those signals in similar ways. The correlation is embedded in the models themselves rather than arising solely from common exposures.

The third channel involves the convergence of model objectives. Financial institutions face similar regulatory requirements, similar competitive pressures, and similar risk-return objectives. When AI systems are optimised against similar loss functions and constraints, they tend to converge on similar strategies even if developed independently. This is analogous to the pre-2008 convergence of risk models around Gaussian copula approaches, but potentially more pervasive because AI models influence a broader range of decisions across the institution.

5.2 Consequences During Periods of Stress

During normal market conditions, this correlation may be invisible because diverse market conditions provide sufficient variation to mask underlying structural similarities. However, during periods of stress, the correlation becomes acutely problematic.

First, correlated risk assessments lead to simultaneous risk reduction. If many institutions' AI systems simultaneously reassess credit risk, market risk, or counterparty risk upward during a stress event, the resulting portfolio adjustments will be correlated. Multiple institutions attempting to reduce exposure to the same asset classes at the same time creates selling pressure that exceeds normal market absorption capacity. This is the classic mechanism of a liquidity crisis, but potentially accelerated and amplified by the speed and correlation of AI-driven decisions.

Second, correlated models may exhibit simultaneous failure under novel conditions. AI models trained on historical data share a common vulnerability to unprecedented events. When a genuinely novel stress scenario materialises, models that share training data and architectural assumptions are likely to fail in correlated ways, producing unreliable outputs simultaneously across multiple institutions. This creates a situation where many institutions simultaneously lose confidence in their risk assessments, potentially leading to defensive over-reactions that amplify the stress.

Third, the feedback between AI actions and market conditions creates the potential for self-reinforcing spirals. If correlated AI-driven selling depresses prices, these price movements feed back into the models as new data, potentially reinforcing the negative signal and triggering further correlated selling. The speed of AI decision-making compresses the timeline of this feedback loop, potentially creating rapid spirals that outpace human intervention and traditional market circuit breakers.

The FSB's concern is therefore that AI adoption, while potentially beneficial for individual institutional efficiency, may inadvertently create a new form of systemic interconnectedness that operates through shared models and data rather than through balance sheet linkages. This form of interconnectedness is largely invisible to existing supervisory frameworks designed to monitor direct financial exposures between institutions.

6 Question 6: Fairness and Bias Mitigation

For a credit scoring application in a bank, bias mitigation must be addressed across the entire model lifecycle. The three stages of intervention—pre-processing, in-processing, and post-processing—target different sources of unfairness and operate through distinct mechanisms.

6.1 Pre-processing: Reweighting Training Samples

At the data level, a common source of bias in credit scoring is historical lending discrimination. If the bank’s historical data reflects past practices where certain demographic groups were systematically denied credit or offered unfavourable terms, a model trained directly on this data will learn to replicate these patterns. The training data effectively encodes societal bias as statistical regularity.

A specific pre-processing technique to address this is sample reweighting. This involves assigning different weights to training observations such that the weighted dataset exhibits equal positive outcome rates across protected groups, conditional on legitimate risk factors. For example, if historical data shows that female applicants with identical income, employment stability, and debt levels to male applicants were approved at lower rates, the reweighting procedure would increase the weight of approved female observations and decrease the weight of approved male observations until the conditional approval rates are equalised.

The mechanism works by presenting the model with a training distribution that reflects what lending decisions would have looked like in the absence of discriminatory patterns, while preserving the legitimate statistical relationships between risk factors and outcomes. The model then learns from a debiased version of reality rather than from the biased historical record.

6.2 In-processing: Adversarial Debiasing

At the model training level, bias can be addressed by modifying the learning objective to incorporate fairness constraints directly. A specific technique is adversarial debiasing, which augments the primary prediction task with an adversarial component that penalises the model for producing outputs that are predictive of protected group membership.

In a credit scoring context, this works as follows. The primary network learns to predict creditworthiness from applicant features. Simultaneously, an adversarial network attempts to predict the applicant’s protected characteristic, such as gender or ethnicity, from the primary network’s internal representations or outputs. The primary network is trained to maximise predictive accuracy while minimising the adversary’s ability to infer group membership. This forces the primary network to learn representations that are informative about credit risk but uninformative about protected characteristics.

The result is that the credit score itself does not encode demographic information, even implicitly through correlated features. The adversarial training pressure forces the model to base its predictions on factors that are genuinely relevant to creditworthiness rather than serving as proxies for group membership.

6.3 Post-processing: Group-Specific Threshold Calibration

At the output level, bias can be addressed by adjusting the decision threshold applied to model scores to achieve equitable outcomes across groups. A specific technique is equalised odds calibration, which sets different classification thresholds for different groups such that the true positive rate and false positive rate are approximately equal across groups.

In credit scoring, this means that after the model produces a continuous risk score, the threshold for approval may differ across demographic groups. If the model systematically assigns higher risk scores to a particular group due to residual bias that pre-processing and in-processing have not fully eliminated, the approval threshold for that group is lowered to ensure that equally creditworthy individuals from different groups face equal probabilities of approval and equal probabilities of incorrect denial.

The principle here is that fairness should be assessed at the decision level rather than the score level. Even if the underlying scores contain residual bias, the final lending decision can be made equitable by calibrating the mapping from scores to decisions separately for each group. This approach preserves the model’s risk-ordering capability within groups while ensuring that inter-group comparisons are fair. In practice, however, this technique requires careful legal review, because using protected attributes directly at the decision stage may itself create compliance concerns in certain jurisdictions. Institutions would need to ensure that any group-specific threshold adjustment is legally permissible under applicable anti-discrimination law.

6.4 Integration Across Stages

In practice, these techniques are most effective when used in combination. Pre-processing reduces the bias that the model is exposed to during training. In-processing prevents the model from learning new discriminatory patterns from residual bias in the data. Post-processing provides a final correction to ensure that the deployed decision system achieves the institution’s fairness objectives. Relying on any single stage alone is generally insufficient because bias can enter and persist through multiple channels simultaneously.

7 Question 7: Transparency and Explainability Layers

7.1 Why Different Stakeholders Require Different Explanations

The principle of layered transparency recognises that explanation is not a single, universal concept but a communication act that must be calibrated to the recipient’s knowledge, needs, and decision context. Different stakeholders interact with AI systems in fundamentally different ways, seek different types of understanding, and will use explanations for different purposes. Providing the same level of detail to all stakeholders would either overwhelm non-technical users with incomprehensible information or provide insufficient detail for technical auditors to perform their function.

The general public primarily needs assurance that AI governance exists and that their interests are protected. They are not making specific decisions based on AI outputs and do not require technical detail. End users are individuals directly affected by AI decisions who need to understand why a particular outcome occurred and what they might do differently. Their explanations must be actionable and comprehensible without requiring technical expertise. Domain experts, such as compliance officers or risk managers, need to understand whether the model’s behaviour aligns with institutional policies and regulatory requirements. They require more detail about the model’s reasoning process and its relationship to domain knowledge. Technical auditors need complete access to model internals, training procedures, performance metrics, and failure modes in order to independently assess whether the system meets regulatory and safety standards.

7.2 End User Level: Loan Decision Scenario

For an end user who has been denied a loan, an appropriate explanation would communicate the following: the primary factors that contributed to the denial, expressed in terms the applicant can understand and potentially act upon. For example: “Your application was not approved at this time. The principal factors in this decision were: your current debt-to-income ratio of 48%, which exceeds our guideline of 40%; limited credit history length of 14 months; and two missed payments recorded in the past 12 months. Improving in these areas may strengthen future applications.”

This explanation is appropriate for the end user level because it identifies specific, actionable factors without revealing the model’s internal architecture, weighting scheme, or decision threshold. The applicant understands what influenced the decision and what they could change, which satisfies the right to explanation and enables recourse. The explanation does not disclose how different factors were combined, what other applicants’

profiles look like, or where exact thresholds lie, information that would not be useful to the applicant and could potentially enable gaming of the system.

7.3 Technical Auditor Level: Loan Decision Scenario

For a technical auditor reviewing the same loan decision system, appropriate information would include: the complete model architecture and its justification; the full feature set used, including any derived or engineered features; the training data composition, including temporal coverage, demographic distribution, and labelling methodology; performance metrics disaggregated by protected characteristics including accuracy, true positive rate, false positive rate, and approval rates; feature importance analyses such as SHAP values showing which variables most influence predictions at both the global and local level; stability metrics demonstrating model performance consistency over time; documentation of the fairness testing regime including the specific fairness criteria applied and the results of disparate impact testing; the governance process for model updates and monitoring; and any known limitations or failure modes of the system.

This level of detail is appropriate for technical auditors because their function is to independently verify that the system operates as intended, complies with regulatory requirements, does not discriminate unlawfully, and remains fit for purpose over time. They need sufficient information to reproduce the institution’s own analyses and to identify potential issues that internal teams may have overlooked. Providing only end-user-level explanations to auditors would be entirely insufficient for this purpose.

7.4 Justification for Differentiation

The layered approach serves both practical and normative purposes. Practically, it ensures that each stakeholder receives information calibrated to their capacity to interpret it and their legitimate need for it. Normatively, it balances the value of transparency against legitimate concerns including system security, competitive sensitivity, and the cognitive burden on non-expert recipients. A one-size-fits-all approach would inevitably either under-serve auditors or overwhelm consumers, failing both groups simultaneously.

8 Question 8: Accountability in the AI Value Chain

8.1 The Air Canada Chatbot Case

In the Air Canada chatbot case, a customer inquired about bereavement fare policies through the airline’s AI-powered chatbot. The chatbot, operating as a customer-facing generative system, provided the customer with information about a bereavement discount

and instructed the customer to book a full-fare ticket and then apply for a retroactive discount within 90 days. The customer relied on this information, booked the ticket, and subsequently applied for the discount. Air Canada denied the claim, stating that no such retroactive application policy existed and that the chatbot had provided incorrect information.

Air Canada argued before the tribunal that the chatbot’s incorrect response should not bind the company and that the customer should have verified the information against the airline’s official website. The tribunal rejected both arguments and held Air Canada fully liable for the chatbot’s representations, reasoning that the chatbot was part of the airline’s customer service offering and that Air Canada was responsible for all information provided through its channels.

8.2 Where the Accountability Gap Occurred

The accountability gap in this case existed at the deployer level. Air Canada, as the organisation that deployed the generative AI chatbot in a customer-facing capacity, failed to establish adequate governance mechanisms between the AI system’s outputs and the representations made to customers. The specific failures were as follows.

First, there was no output validation mechanism ensuring that the chatbot’s responses were consistent with actual company policies. The system was capable of generating plausible but incorrect information about fare policies without any verification against an authoritative policy database. This represents a failure of the deployer to implement grounding mechanisms that constrain generative outputs to verified institutional knowledge.

Second, there was no human oversight layer for consequential customer interactions. The chatbot operated autonomously in providing policy information that customers would reasonably rely upon for financial decisions, without any escalation mechanism for queries involving specific commitments or financial representations.

Third, there was no accountability assignment within the organisation for the chatbot’s outputs. The attempt to disclaim responsibility revealed that no individual or team had been assigned clear ownership of ensuring the accuracy of its customer communications.

8.3 Governance Mechanisms That Could Have Prevented Harm

Several governance mechanisms, aligned with the accountability framework’s identification of roles across the AI value chain, could have prevented this outcome.

At the deployer level, the institution should have implemented a policy grounding requirement: all chatbot responses concerning specific fare policies, refund procedures, or

financial commitments should be generated only from a verified and maintained policy database rather than from general model knowledge. This ensures that the system cannot fabricate policies that do not exist.

At the system integration level, an output classification and escalation framework should have been implemented. Customer queries involving financial commitments, policy interpretations, or time-sensitive decisions should be automatically classified as high-risk and either routed to human agents or flagged for real-time human review before delivery.

At the governance body level, a pre-deployment testing regime specifically targeting policy accuracy should have been conducted. This would involve systematically querying the chatbot about known policies and verifying that responses are accurate, complete, and consistent with official documentation. Any hallucinated policies discovered during testing would signal that the system is not ready for autonomous customer interaction.

Additionally, a clear internal accountability assignment should have designated specific roles responsible for the chatbot’s accuracy. This includes technical teams responsible for maintaining the grounding database, compliance teams responsible for approving the scope of autonomous chatbot interactions, and operational teams responsible for monitoring and correcting errors in real time.

The Air Canada case demonstrates that deploying generative AI in customer-facing roles without these governance mechanisms creates an accountability vacuum that ultimately the deploying institution cannot escape. Regulatory and judicial authorities will not accept the delegation of institutional responsibility to autonomous systems.

9 Question 9: Hong Kong Privacy Framework

9.1 Human Oversight and Privacy Protection in GenAI

The Hong Kong Privacy Commissioner’s AI Model Personal Data Protection Framework (2024) recognises that generative AI systems create novel privacy challenges that cannot be addressed through technical safeguards alone. The principle of human oversight applies to privacy protection by requiring that meaningful human judgment is interposed at critical points in the GenAI lifecycle where personal data may be at risk of improper collection, use, disclosure, or retention.

In the context of generative AI, human oversight for privacy protection is particularly important because these systems process and generate information in ways that are less predictable than traditional data processing systems. A conventional database query either returns personal data or it does not, and access controls can be definitively enforced. A generative AI system, by contrast, may inadvertently reproduce personal information

memorised during training, infer personal attributes from seemingly non-personal inputs, or generate synthetic outputs that are sufficiently similar to real individuals to constitute personal data under privacy law.

Human oversight therefore serves as a necessary complement to technical privacy controls because it provides contextual judgment that automated systems cannot replicate. A human reviewer can assess whether a generated output contains information that could identify an individual in context, even if no single data element constitutes personal data in isolation. A human can also evaluate whether the purpose of a particular data processing activity remains consistent with the original collection purpose, a determination that requires understanding institutional intent rather than merely applying pattern matching.

9.2 Practice 1: Privacy Impact Assessment with Human Review at Each Lifecycle Stage

Organisations should implement mandatory privacy impact assessments with designated human reviewers at each stage of the GenAI lifecycle: data collection and preparation, model training, deployment, and ongoing operation. This means that before training data is assembled, a privacy officer reviews the data sources to verify that personal data has been collected with appropriate consent and legal basis, and that data minimisation principles have been applied. Before model deployment, a human reviewer assesses whether the model's outputs in testing have revealed any tendency to reproduce personal information from training data. During operation, designated reviewers periodically audit model outputs to check for privacy-relevant content.

This practice ensures meaningful oversight because it requires human judgment at precisely the points where privacy risks materialise. It is not sufficient to conduct a single privacy review before deployment and then operate the system autonomously. Generative AI systems may exhibit emergent behaviours during operation that were not apparent during testing, and the data environment in which they operate may change over time. Continuous human oversight ensures that privacy protection adapts to these changes rather than remaining static.

9.3 Practice 2: Human-Gated Escalation for Outputs Involving Personal Data

Organisations should implement automated detection mechanisms that flag generative AI outputs potentially containing personal data, combined with mandatory human review before such outputs are delivered to end users or stored in institutional systems. This involves deploying named entity recognition, pattern matching for identification numbers,

and contextual analysis to detect when a generative system’s output may contain personal information. When such content is detected, the output is withheld from delivery and routed to a trained privacy reviewer who assesses whether the content constitutes personal data, whether its disclosure is authorised, and whether it should be redacted, modified, or suppressed.

This practice provides meaningful oversight because it addresses the specific risk that generative AI systems may produce outputs containing personal data without any explicit instruction to do so. Unlike traditional systems where personal data flows through defined channels, generative systems may surface personal information in unexpected contexts. The human-gated escalation ensures that these unexpected disclosures are caught and evaluated before they create privacy breaches, while the automated detection layer ensures that the volume of generative outputs does not overwhelm human review capacity by filtering only those outputs that present genuine privacy risk.

10 Question 10: Hallucinations and Model Risk

10.1 Three Safeguards for High-Risk Use Cases

10.1.1 Safeguard 1: Mandatory Grounding with Source Attribution

For high-risk use cases such as customer-facing guidance or compliance interpretation, all generative AI outputs should be grounded in verified, authoritative source documents through retrieval-augmented generation or equivalent mechanisms. The system should be architecturally constrained to generate responses only when supported by retrieved source material, and every substantive claim in the output should be accompanied by a traceable citation to the specific document, section, and version from which it derives.

This safeguard addresses hallucination risk by changing the system’s failure mode. Without grounding, the system can generate plausible but fabricated content from its parametric knowledge. With mandatory grounding, the system is constrained to synthesise and rephrase verified information rather than generating novel claims. When the system cannot find relevant source material to support a response, it is designed to acknowledge this limitation explicitly rather than fabricating an answer.

In a compliance interpretation context, this means the system can only provide guidance that is traceable to specific regulatory texts, internal policies, or authoritative guidance documents. If asked about a topic for which no relevant source material exists in its retrieval corpus, it states that it cannot provide guidance rather than constructing a plausible but potentially incorrect interpretation.

10.1.2 Safeguard 2: Multi-Layer Output Validation

High-risk outputs should pass through automated validation checks before delivery, including logical consistency verification, numerical accuracy checks, cross-reference validation against authoritative databases, and contradiction detection against known institutional rules. This creates a structured quality gate between generation and delivery that catches categories of hallucination that grounding alone may not prevent.

For customer-facing guidance, this might include verifying that any product terms mentioned in a response match the institution’s current product database, that any regulatory references correspond to actual provisions, and that numerical calculations are arithmetically correct. For compliance interpretation, it might include checking that cited regulations are current rather than superseded, that the interpretation is consistent with the institution’s previously documented positions, and that mandatory caveats and limitations are included.

This safeguard is effective because many hallucinations can be detected through automated comparison against structured reference data, without requiring human review of every output. It creates a scalable defence layer that catches factual errors while reserving human oversight capacity for judgmental issues that automation cannot resolve.

10.1.3 Safeguard 3: Human Review with Defined Escalation Criteria

For outputs that pass automated validation but involve material risk—such as novel compliance interpretations, significant financial recommendations, or communications that could create institutional liability—mandatory human review by qualified professionals should be required before delivery. Clear escalation criteria should define which categories of output require human review, and qualified reviewers should have the authority to approve, modify, or reject the AI-generated content.

This safeguard provides the final defence against hallucinations that are too subtle or context-dependent for automated detection. A hallucinated but internally consistent compliance interpretation, for example, might pass all automated checks but be recognised as incorrect by an experienced compliance officer who understands regulatory intent and institutional context. Human review ensures that domain expertise is applied to the most consequential outputs, providing a quality standard that purely technical safeguards cannot achieve.

10.2 Why Traditional Model Validation is Insufficient for GenAI

Traditional model validation approaches were designed for systems with fundamentally different properties from generative AI. Their insufficiency for GenAI stems from several

structural incompatibilities.

First, traditional validation assumes bounded output spaces. A credit scoring model produces a numerical score within a defined range, and validation assesses whether the distribution of scores, their discrimination power, and their calibration meet defined standards. Generative AI produces open-ended natural language outputs from an effectively infinite output space. There is no defined range to validate against, no single metric that captures output quality, and no way to enumerate all possible outputs for testing.

Second, traditional validation relies on ground truth comparison. Models are validated by comparing predictions against known outcomes: did the borrowers predicted to default actually default? Generative AI outputs often have no single ground truth. A summary of a regulatory document could be correct in many different ways, and determining whether a particular summary is “right” requires human judgment rather than mechanical comparison against a reference.

Third, traditional validation assumes deterministic or statistically stable behaviour. Given the same input, a validated model should produce the same or statistically predictable output. Generative AI systems may produce different outputs for identical inputs depending on sampling parameters, and their behaviour may drift as the context window accumulates different interaction histories. This non-determinism means that validation results from one testing session may not generalise to future operational behaviour.

Fourth, traditional validation addresses known failure modes. Models are stress-tested against scenarios derived from historical experience or theoretical risk factors. Generative AI can fail in ways that are novel and difficult to anticipate, producing outputs that are superficially plausible but substantively wrong in ways that no predefined test case would capture. The hallucination problem is not merely a matter of model accuracy degrading at distribution boundaries; it is the potential for confident confabulation that has no analogue in traditional predictive models.

Fifth, traditional validation frameworks are designed for periodic review of static models. Models are validated at deployment and periodically thereafter. Generative AI systems, particularly those incorporating retrieval-augmented generation or operating with conversational context, are effectively dynamic systems whose behaviour changes with every interaction. The concept of validating a fixed model at a point in time does not translate naturally to systems that are constantly adapting their behaviour to new inputs.

These structural differences mean that financial institutions cannot simply extend existing model risk management frameworks to cover generative AI. They must develop new validation paradigms that address open-ended outputs, contextual correctness, non-deterministic behaviour, and novel failure modes, supplemented by the operational safe-

guards described above that provide ongoing protection rather than point-in-time assurance.